Q1.1 Scope

1 Point

(2+ stakeholders, 2-3 sentences each): Identify who must comply with the regulation, what activities or information are regulated, and which part(s) of the regulation your team is studying.

1. Manufacturers of products with digital elements

Manufacturers that place software, hardware, or products containing digital elements on the EU market are the primary organizations that must comply with the CRA. They must assess cybersecurity risks, design and maintain secure products, identify and remediate vulnerabilities, provide security updates, and maintain documentation demonstrating compliance. Our team is focusing especially on the manufacturer obligations in Article 13 and the vulnerability-handling requirements in Annex I, Part II [1, Art. 13; Annex I, Parts I–II]. Article 13 requires manufacturers to assess cybersecurity risks throughout product planning, design, development, production, delivery, and maintenance.

2. Importers and distributors

Importers and distributors that place or make these products available in the EU also have compliance responsibilities. They must verify that products meet CRA requirements, have the required documentation and markings, and take action or notify relevant parties when they discover noncompliance or cybersecurity risks **[1, Arts. 19–20]**. The final regulation specifically requires distributors to verify CE marking and required documentation before making a product available.

3. Cybersecurity authorities / Computer Security Incident Response Teams (CSIRTs) and European Union Agency for Cybersecurity (ENISA)

EU cybersecurity authorities, including designated CSIRTs and ENISA, receive vulnerability and incident reports from manufacturers. Our team is studying the Article 14 reporting process, including the information manufacturers must provide for actively exploited vulnerabilities, such as an early warning within 24 hours, a vulnerability notification within 72 hours, and a final report no later than 14 days after a corrective or mitigating measure becomes available [1, Art. 14].

References:

[1] European Parliament and Council of the European Union, "Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements … (Cyber Resilience Act)," *Official Journal of the European Union*, Nov. 20, 2024. [Online]. Available: EUR-Lex. Official EUR-Lex source

Q1.2 Key obligations

1 Point

Grading comment:
Identify at least two software-relevant obligations. For each, provide:

The source of the obligation

- Required action and applicable conditions
- Evidence that would demonstrate compliance
- The consequences of failing to meet the selected obligation

Vulnerability identification and handling:
Required action:
Manufacturers must identify and document vulnerabilities and software components in their products, including creating a software bill of materials (SBOM) in a commonly used, machine-readable format. They must also address vulnerabilities without undue delay, provide security updates, and regularly test and review the security of the product throughout its support period.

Evidence compliance:
Evidence could include the SBOM, vulnerability records, security-test reports, patch/update histories, documented vulnerability-handling procedures, and records showing when vulnerabilities were discovered and fixed. Annex VII specifically identifies documentation of vulnerability-handling processes, the SBOM, coordinated vulnerability-disclosure policy, update mechanisms, and test reports as technical compliance evidence.

Consequences:
Failure to comply with the essential cybersecurity requirements in Annex I or the manufacturer obligations in Article 13 can result in administrative fines of up to €15 million or 2.5% of the company's total worldwide annual turnover from the previous financial year, whichever is higher. Authorities can also require corrective action or potentially restrict, withdraw, or recall a noncompliant product

[1, Art. 13(6)–(8); Annex I, Part II]

Reporting actively exploited vulnerabilities and severe security incidents:
Required action:
When a manufacturer becomes aware of an actively exploited vulnerability, it must notify the designated CSIRT and ENISA through the CRA reporting system. An early warning must be submitted within 24 hours, a more detailed vulnerability notification within 72 hours, and a final

report no later than 14 days after a corrective or mitigating measure becomes available. Similar 24- and 72-hour requirements apply to severe security incidents affecting the product.

Evidence compliance:
Evidence could include copies or confirmation receipts of submitted notifications, timestamps showing when the vulnerability was discovered and reported, incident records, vulnerability descriptions, mitigation actions, security-update records, and the final report submitted to the relevant authorities.

Consequences:
Failure to satisfy Article 14 can also result in administrative fines of up to €15 million or 2.5% of worldwide annual turnover, whichever is higher.

[1, Art. 14]

References:

[1] European Parliament and Council of the European Union, "Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements … (Cyber Resilience Act)," *Official Journal of the European Union*, Nov. 20, 2024. [Online]. Available: EUR-Lex. Official EUR-Lex source

Q1.3 Ambiguity

1 Point

Grading comment:
(3-4 sentences): Identify one place where the regulation leaves room for interpretation or engineering judgment, and explain its effect on the project your team may decide to pursue.

One area of ambiguity in the CRA is the requirement that products with digital elements provide an "appropriate level of cybersecurity based on the risks" [1, Annex I, Part I]. While Article 13 gives guidance by requiring manufacturers to consider factors such as the product's intended use, operating environment, assets to be protected, and expected lifetime, the regulation does not define one specific set of security controls or technical implementation that is appropriate for every product, so manufacturers must use engineering judgment based on the product's purpose, environment, and cybersecurity risks. This could affect our project by requiring any system we develop to support configurable or risk-based compliance decisions rather than applying the same security rules to every product. Our system may also need to record the reasoning and

evidence behind those decisions so that the manufacturer can demonstrate why its chosen controls were appropriate.

References:

[1] European Parliament and Council of the European Union, "Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements … (Cyber Resilience Act)," *Official Journal of the European Union*, Nov. 20, 2024. [Online]. Available: EUR-Lex. Official EUR-Lex source

Q2 Modeling the Regulatory Challenge
2 Points
Grading comment:
Develop models that make the important parts of the regulatory challenge explicit.
Question 2.1 Workflow and boundary models

Q2.1 Workflow and boundary models
1 Point
Grading comment:
Create one or two diagrams showing the main participants, their responsibilities, and the major activities involved in addressing those obligations identified in Section 1.
Show decision points where a condition changes what happens next. State the condition as a question, label the possible outcomes, and show the action that follows each outcome. Include important exceptions—for example, missing information, a missed deadline, or a review finding that an obligation has not been met.
Show how the people, organizations, and external systems interact. Indicate which activities might benefit from software support and which responsibilities would remain outside that software's scope. This boundary is preliminary and does not bind your team to a particular system design.
Simplify deliberately: include the activities, relationships, and decisions needed to understand the challenge. You do not need to represent every detail of the regulation or every possible exception.
Simple labeled boxes, stick figures, and arrows are acceptable. Formal UML notation is not required, though you may use it – specifically, consider models such as use case diagrams and activity diagrams. You may supply whiteboard drawing, (vetted) LLM drawing of your model, draw.io or mermaid.js, etc.

Diagram 1

https://drive.google.com/file/d/1LOgODj-g4UZWhX-tVRUY-qR4z_D0dUEZ/view?usp=sharing

Diagram 2
https://drive.google.com/file/d/1H3ydkl5F_9iUN9sPomOzAxDDN1KWVSR2/view?usp=sharing

Q2.2 Explanation

The workflow model helped us understand how vulnerability handling and CRA reporting are connected, especially how different decisions determine whether reporting obligations are triggered. It also showed that software could support tasks such as matching vulnerabilities to affected products, tracking deadlines, storing evidence, and preparing reports, while final engineering and compliance decisions remain with people. This connects directly to the CRA's vulnerability-management and Article 14 reporting obligations because missing information, missed deadlines, or incorrect impact assessments can lead to noncompliance. We assume that engineering personnel determine technical impact and remediation, while compliance personnel are responsible for reviewing and approving regulatory reports before submission.

Q3: Existing-Solution Analysis

Solution 1: OWASP Dependency-Track

OWASP Dependency-Track is a platform that imports CycloneDX software bills of materials (SBOMs) and regularly checks their components for known vulnerabilities [2]. It supports the vulnerability-identification requirements in Annex I, Part 2 of the CRA by tracking component usage across application versions, helping manufacturers identify affected releases and prioritize investigation [1, 2]. However, it relies on supplied SBOMs, so we need to verify their completeness and ensure they accurately represent the software deployed on products. We would reuse its component analysis and integrate SBOM generation and uploading into our CI/CD pipeline, with additional engineering to connect each release's findings to our deployed-product inventory.

Solution 2: TheHive

TheHive, developed by StrangeBee, is an incident-response platform that organizes investigations into cases with assigned tasks, supporting evidence, and customizable templates [3]. It complements Dependency-Track by helping engineering and compliance personnel coordinate investigations and preserve the information needed to prepare CRA Article 14 notifications [1, 3]. Before adopting it, we would need to investigate how its workflows could support the required reporting fields and deadlines measured from when the manufacturer becomes aware of a reportable vulnerability or incident. We would reuse its case management, configure reporting templates, and develop deadline tracking and report exports, reducing manual coordination while leaving report approval and submission to compliance personnel.

[2] OWASP, *Dependency-Track*: Introduction and Continuous Integration & Delivery.
[3] StrangeBee, *TheHive: Overview*.

Q4.1

Manufacturers must document software components in a machine-readable Software Bill of Materials (SBOM), as required by Article 13 and Annex I of the Cyber Resilience Act (CRA). Today, they manually compile dependency lists during final testing and store them in static documents. However, these static lists become instantly outdated as sub-dependencies change, making it difficult to rapidly locate vulnerable components across deployed devices. Software could automate this by generating SBOMs directly within Continuous Integration/Continuous Deployment (CI/CD) pipelines during every containerized build; success would be observable if organizations can query their entire production inventory for newly discovered vulnerabilities within seconds.

Q4.2

Manufacturers must notify the Computer Security Incident Response Team (CSIRT) and the EU Agency for Cybersecurity (ENISA) of actively exploited vulnerabilities within 24 hours, as required by Article 14 of the Cyber Resilience Act (CRA). Today, they manually review disconnected system alerts, investigate impacts, and draft compliance reports from scratch. However, coordinating across disparate systems takes too much time, risking the 24-hour reporting deadline and millions in potential fines. Software could aggregate verified vulnerability alerts into structured incident cases with automated deadline tracking and pre-filled CRA report templates; success would be observable if the time from initial incident awareness to a staged, compliance-ready report drops to under one hour.

Q5.1 Concept 1

Name and purpose

The Automated Software Bill of Materials (SBOM) and Vulnerability Tracking System is designed for software developers, security engineers, and compliance managers. It addresses the

problem of outdated component lists by helping organizations meet their Cyber Resilience Act (CRA) obligations under Article 13 and Annex I to maintain an accurate list of parts and identify vulnerabilities.

Responsibilities and scope

The system automatically creates an SBOM during each build in the Continuous Integration and Continuous Deployment (CI/CD) pipeline, stores it by product release, and checks components against known vulnerability feeds. This improves on the current approach of manually writing static spreadsheets during testing that quickly become outdated. The system is limited to tracking parts and flagging affected versions, leaving actual code fixes and final compliance sign-offs to the human engineering team.

Inputs and outputs

The system receives build files, package dependency manifests, release version tags, and public vulnerability data feeds. It produces standard CycloneDX-formatted SBOM files, an indexed inventory of product releases, and alerts showing which shipped versions contain a reported vulnerability.

Evaluation

For example, when a new security flaw is reported in a common open-source library, an engineer can ask the system which supported product releases contain that broken library and receive an accurate list within seconds. Another team could check this result by adding a known vulnerable component into a test build and timing how quickly the system flags the affected release.

Engineering risk

The main technical uncertainty is that build tools might miss indirect dependencies or system-level files, producing an incomplete SBOM. If parts are missing from the list, the system will fail to alert engineers when those hidden parts are attacked, giving a false sense of security. To reduce this risk, the team could build a small prototype that compares SBOMs generated during the build against deep scans of the final container image to measure how many parts were missed.

Potential reuse

We would reuse Open Web Application Security Project (OWASP) Dependency-Track for component analysis and vulnerability matching, and reuse open-source tools like Syft to build the SBOMs during the pipeline. This allows our team to focus on the release tracking and version inventory without having to build a vulnerability scanner from scratch.

Q5.2 Concept 2

Name and purpose

The Cyber Resilience Act (CRA) Article 14 Incident Reporting System is built for incident response leads and product security teams. It addresses the problem of slow manual coordination by helping organizations meet the Article 14 obligation to report actively exploited vulnerabilities and severe incidents to European authorities within strict deadlines.

Responsibilities and scope

The system logs the exact moment an engineer confirms an active attack, tracks the required 24-hour, 72-hour, and 14-day deadlines, and pre-fills regulatory report forms with product details. This improves on the current approach of using generic tickets and writing reports from scratch under tight time pressure. Its scope is limited to organizing evidence and tracking deadlines, leaving the legal decision of whether an issue must be reported and the actual submission to human compliance personnel.

Inputs and outputs

The system receives security alerts, exploit reports, product version records, and an engineer's timestamped confirmation that an attack is occurring. It produces active countdown timers, pre-filled report drafts formatted for the European Union Agency for Cybersecurity (ENISA), and a tamper-proof audit record of the response timeline.

Evaluation

For example, during an active security incident, a responder can confirm an attack and have the system produce a ready-to--review early warning draft in under one hour. Another team could check this by running a mock attack exercise, recording the start time, and measuring how long it takes the system to prepare the draft report and alert managers.

Engineering risk

The main technical uncertainty is keeping deadline timers and alert states accurate if the system crashes or restarts during an active incident. If a timer fails or resets, the company could miss the strict 24-hour reporting deadline and face heavy fines. To resolve this uncertainty, the team could build a prototype using a durable workflow engine to confirm that active countdowns and reminders survive server restarts and network interruptions.

Potential reuse

We would reuse TheHive, an open-source incident response tool developed by StrangeBee, to handle investigation cases, store evidence, and assign tasks. Our team would then build custom templates and timer logic on top of it to handle the specific CRA reporting deadlines.

Q6.
Meeting Date: 9/13/2026
Attending Teams: Team 2, Team 6
Attendees: Chris Feng, Pataraphol Keeraswangporn, Jared Dong, Ansh Kothari, Sathvik Valluri, Daksh Agarwal, Donovan Baran, Sanjay Sriram

The most consequential takeaway from our discussion was the other team pointing out that the Cyber Resilience Act (CRA) requires a Software Bill of Materials (SBOM), a list of all parts in a program, for every release sold, not just the main code. This changed our plan that we cannot only scan our latest builds. Instead, our tool must save a list of parts for each shipped version and track its support window. This ensures older products are still easy to search when new flaws, known as Common Vulnerabilities and Exposures (CVEs), come out.

Our main disagreement was about how much documentation is legally needed before starting the 24-hour clock for Article 14 incident reporting. We wanted our software to draft reports right away from system alerts to save time. Team 6 argued that raw alert data is not enough documentation to prove an active attack, and filing without human-verified records could lead to bad filings with the European Union Agency for Cybersecurity (ENISA). To resolve this, we must study official guidance to see what evidence baseline legally counts as being "aware" of an attack. For Phase 2, a good option is having the system collect the required evidence documents first, while letting an engineer officially review them to start the timer.